HyperDX ClickHouse-proxy SSRF

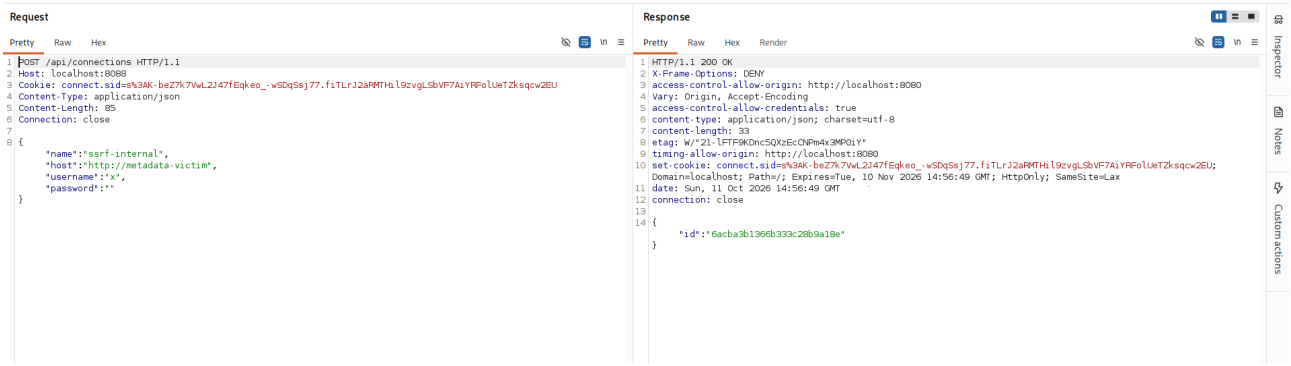
Researcher	Kashish Topiwala
Product	HyperDX (hyperdxio/hyperdx)
Affected	@hyperdx/api 2.40.0 and earlier
CWE	CWE-918 Server-Side Request Forgery
CVSS 3.1	9.1 Critical (AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L)

Summary

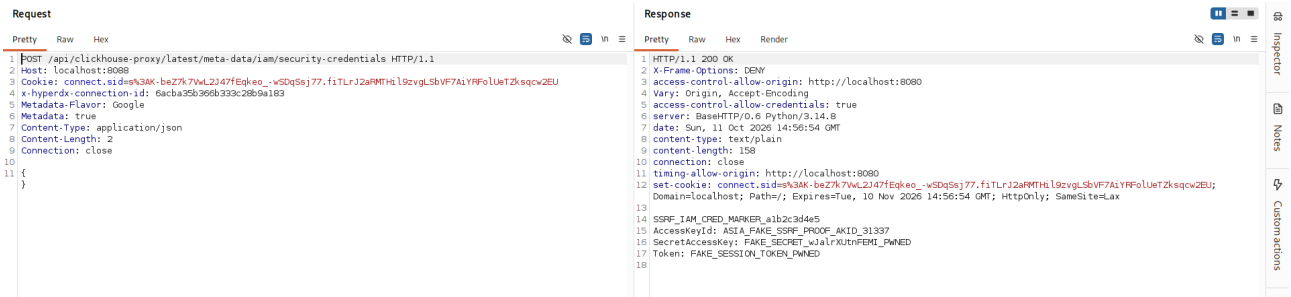
HyperDX is an observability platform. The ClickHouse proxy forwards a request to the host of a user-created connection. The connection host is not checked, so a low-privilege user can set it to an internal address. The server fetches that address and returns the response body, and forwards attacker-supplied headers, which reaches internal services and the cloud metadata endpoint.

Steps to reproduce

1. Register the first user on a fresh single-team install. This user is a normal low-privilege account.
2. Create a connection with the host set to an internal address. The server accepts it with no validation.



3. Send POST /api/clickhouse-proxy/ with the connection id in the x-hyperdx-connection-id header and an attacker header such as Metadata-Flavor.
4. Confirm the server returns 200 with the internal service body. The response server header shows the internal service, and the attacker Metadata-Flavor header was forwarded.



Impact

- A low-privilege user makes the server read internal-only services.
- The server returns the internal response body to the attacker.
- Attacker-controlled headers are forwarded, so the request can reach a cloud metadata endpoint and expose credentials.
- The connection host accepts 169.254.169.254 and other private addresses with no check.

Remediation

- Reject private, loopback, link-local, and metadata addresses on the proxy before forwarding the request.
- Re-check the host after DNS resolution to stop rebinding.
- Do not forward attacker-controlled headers to the connection host.

References

- https://github.com/hyperdxio/hyperdx/blob/main/packages/api/src/routers/api/clickhouseProxy.ts
- https://cwe.mitre.org/data/definitions/918.html